

대시보드 접근 권한 가이드

CMS 매출 대시보드([SEOBUK](#) · [콘텐츠운영팀](#))의 계정·권한 운영 문서. 2026-08-12 기준 · 코드 기준으로 작성했고, 근거 파일을 각 항목에 적어 뒀다.

한 장 요약

권한은 서로 다른 세 축이 겹쳐서 정해진다. 헛갈리는 대부분이 이 셋을 하나로 보기 때문이다.

축	정하는 것	어디서 바꾸나
역할 (owner / editor / viewer)	값을 고칠 수 있는가	승인할 때 · 승인 후 계정 목록에서
팀 (IPX-A · PR팀 ...)	어느 메뉴가 보이는가	승인할 때 · 계정 목록의 팀 드롭다운
소유자	관리 화면을 열 수 있는가	코드 고정 — 화면에서 못 바꾼다

역할을 올려도 메뉴가 늘지 않고, 팀을 바꿔도 편집 권한이 생기지 않는다.

1. 역할 — 무엇을 고칠 수 있는가

`auth.py:ROLES` · `auth.get_role()` · `auth.can_edit()`

한눈에

	👁 뷰어	✎ 에디터	👑 소유자
팀에 허용된 메뉴 보기	✓	✓	✓ (전 메뉴)
필터·검색·표 펼치기	✓	✓	✓
데이터 내려받기	✓	✓	✓
IP정산서 열기	✓	✓	✓
IP정산서 확정·저장·발행	✗	✓	✓
환율 직접 입력·저장	✗	✓	✓
각 카드의 계산 방식 설명	✗	✗	✓
KPI 목표 수정·파일 업로드	✗	✗	✓
접속·계정 관리 메뉴	✗	✗	✓

내려받기는 역할과 무관하다. 뷰어도 받을 수 있다. 대신 누가 무엇을 받았는지 전부 기록된다(4장 참고). 이건 의도된 설계다 — 막을 거면 게이트를 새로 넣어야 한다.

👁 뷰어 — 기본값

승인만 되면 이 상태다. 보는 데는 제약이 없다. 필터·검색·순위표·프레임 펼치기·내려받기까지 전부 된다.

다른 점은 IP정산서를 열었을 때뿐이다.

🔍 보기 전용이에요. 확정·발행은 편집 권한이 있어야 해요.

이 안내가 맨 위에 뜨고, 아래 버튼들이 회색으로 눌리지 않는다 — ☒ 이 타이틀로 확정 · 📄 저장 · 📄 이 환율로 저장 · ⬇ 정산서 발행. 숫자와 국가별 표는 그대로 보이므로 확인·대조 용도로는 문제없다.

✎ 에디터 — 정산을 굴리는 사람

뷰어가 하는 것 전부 + IP정산서에서 값을 고치고 문서를 만든다.

열리는 것	무슨 일이 벌어지나
정산 대상 타이틀 체크·티켓 고르기	어떤 매출을 이 IP 것으로 볼지 확정
📄 저장 (요일 R/S · MG · 국가별 요율)	정산 금액이 바뀐다
환율 직접 입력 후 📄 이 환율로 저장	그 기준일 환율이 이후 계산에 쓰인다
정산서 PDF 발행	문서가 만들어지고 발행 이력에 남는다

돈에 직접 영향을 준다. 저장·확정은 활동 로그에 📄 정산 매핑 으로 남는다. 정산 담당이 아니면 뷰어로 두는 게 맞다.

👑 소유자 — 코드에 고정된 3명

에디터가 하는 것 전부 + 아래가 추가로 보인다.

- 사이드바 🔑 관리자 전용 카드 (포토이즘·스내피즘)
 - 계산 방식 설명 체크 → 각 카드 아래에 "이 값은 어떻게 계산되나요?" 접기가 붙는다. 분모·분자·제외 조건까지 적혀 있어 숫자를 의심할 때 여기부터 본다.
 - 🕒 실시간 환율 — 오늘 기준 환율 조회.
- KPI목표 — 🗝 관리자 전용 · 📄 파일 관리 : IPX MASTER DATA 업로드, 목표 직접 수정, 목표 CSV 템플릿, 엑셀 실적 초기화.
- 접속·계정 관리 메뉴 — 승인·역할·팀·활동 로그. 팀 권한으로는 절대 못 연다.
- 모든 메뉴 — 팀 배정과 무관하게 전부 보인다.
- 승인 대행 — 1차·2차 어느 단계든 대신 누를 수 있다(담당자 부재 시).

바꾸는 법

- **뷰어 ↔ 에디터**: 접속·계정 관리 → **계정 승인** → **승인된 계정**의 역할 드롭다운. 즉시 반영된다(상대가 새로고침하면 적용).
- **소유자**: 화면에서 못 바꾼다. `auth.py`의 `OWNER_EMAILS`를 고치고 **재시작**해야 한다.
- 지금 편집 권한이 실제로 걸린 곳은 **IP정산서 한 곳**이다 (`views/8_IP정산서.py:45`의 `CAN_EDIT`). 나머지는 소유자 전용이거나 열람 전용이라, **에디터로 올려도 다른 화면은 아무것도 달라지지 않는다**.

2. 팀 — 어느 메뉴가 보이는가

`auth.allowed_pages()` · `pages_registry.py`

팀은 **메뉴(페이지) 접근만** 정한다. 팀에 편집 권한은 없다.

지금 설정 (2026-08-12)

팀	보이는 메뉴
(팀 없음) = 기본	포토이즘 · 스내피즘 · IP 오픈 캘린더 · KPI목표
IPX-A	스내피즘 · 포토이즘 · SM 촬영현황
IPX-C	스내피즘 · 포토이즘
콘텐츠운영팀	스내피즘 · 포토이즘 · IP 오픈 캘린더
콘텐츠마케팅팀	스내피즘 · 포토이즘 · KPI목표 · 주간리포트
PR팀	스내피즘 · 포토이즘

알아 둘 것

- 팀을 **배정하지 않으면 기본 메뉴**가 보인다. 아무것도 못 보는 게 아니다 (`pages_registry.DEFAULT_PAGES`). 팀 기능을 켜올 때 기존 사용자가 통째로 잠기지 않게 하려고 넣은 안전장치다.
- 팀을 만들고 **체크를 하나도 안 하면**, 차단이 아니라 **기본 메뉴로 되돌아간다**. 의도적으로 좁히려면 반드시 하나 이상 체크해야 한다.
- 팀을 **지우면** 소속이던 계정은 배정만 풀리고 기본 메뉴로 돌아간다. 잠기지 않는다.
- **관리 화면은 팀으로 못 연다**. 소유자만이다(`can_view_page`).
- **숨긴 메뉴는 팀에 체크해도 안 보인다** — 지금 `주간리포트 · 기간 후 매출분석 · IP매출 조회(구)` 셋이 `pages_registry.HIDDEN`으로 감춰져 있다. (콘텐츠마케팅팀에 주간리포트가 체크돼 있지만 감춰져 있어 안 보인다. 되살리려면 `HIDDEN`에서 key를 빼면 저장된 권한이 그대로 살아난다.)

3. 가입 — 신청부터 접속까지

STOBOOK · 콘텐츠운영팀 · 대시보드 접근 권한 가이드 · 2026-08-12

`auth.require_login()` · `_add_pending()` · `_approve_stage1()` · `_approve()`

구글 로그인



 접속 신청 화면 - 본인이 소속 팀을 고르고 메모를 적어 '신청하기'



(누르지 않으면 접수되지 않는다)

1차 승인 유경민 → 역할(에디터/뷰어) 지정



2차 승인 최병민 → 역할·팀 확인 후 최종 승인



접속 가능 + 본인에게 승인 메일

- 둘 다 승인해야 열린다. 1차만 통과한 계정은 아직 못 들어온다.
- 신청할 때 고른 팀이 최종 승인 시 그대로 배정된다. 2차 화면에 그 팀이 기본값으로 잡혀 있고, 승인자가 바꿀 수도 있다. 따로 배정하는 절차는 없다.
- 신청한 팀은 어디까지나 신청이다. 승인자가 확인하지 않으면 아무나 메뉴가 제일 넓은 팀으로 들어온다 — 2차 승인 때 팀을 꼭 보고 누를 것.
- 각 단계에서 메일이 자동으로 나간다(1차 → 2차 → 본인).
- 승인자는 `config.json` 의 `approval.stage1 / stage2` 로 바꾼다. 코드 수정 불필요.
- 소유자는 두 단계 다 대신 누를 수 있다(담당자 부재 시 대행).

4. 기록 — 무엇이 남는가

`auth._log_access()` · 접속·계정 관리 → 활동 로그

남는 것	표시
로그인	✅ 로그인
미승인 계정이 들어와 본 것	👁️ 미승인 접속 시도
가입 신청	⌚ 가입 신청 · 팀 ○○
승인 · 거절 · 해제 · 역할 변경 · 팀 배정/삭제	👍 🚫 🛑 🔧 👤 🗑️
페이지 열람	👁️ 열람 → 페이지명
데이터 내려받기	💾 다운로드 [페이지] 파일명 · 행수 · 용량
정산 매핑 확정 · 정산 제외	📄 🚫

- 데이터 반출은 열람과 성격이 달라 계정·시각·파일명·행수·용량까지 남긴다.

- 로그는 계속 쌓이므로 관리 화면은 **끝부분만** 읽는다(파일 전체를 올리지 않는다).

SEOBUK · 콘텐츠운영팀 · 대시보드 접근 권한 가이드 · 2026-08-12

5. 자주 나오는 상황

"메뉴가 안 보여요" → 팀을 확인한다. 팀이 배정돼 있으면 그 팀의 체크 목록이 전부다. 팀이 없으면 기본 메뉴만 보인다. 감춘 메뉴(`HIDDEN`)는 어떤 팀도 못 본다.

"버튼이 눌리지 않아요" → 역할 문제다. IP정산서의 편집 버튼은 **에디터 이상**이어야 한다. 관리자 전용 도구(환율·계산 설명·KPI 목표)는 **소유자만**이다.

"에디터로 올려 줬는데 달라진 게 없대요" → 정상이다. 편집 권한이 걸린 곳은 **IP정산서 하나뿐**이다. 다른 화면은 뷰어와 같다.

"뷰어인데 데이터를 받을 수 있네요?" → 지금은 **역할과 무관하게 누구나 받을 수 있다**. 대신 계정·시각·파일명·행수·용량이 전부 기록된다. 좁히려면 `auth.download_button` 한 곳에 게이트를 넣으면 전부 한 번에 적용된다(아직 안 넣었다).

"계산 방식 설명이 안 보여요" → 소유자 전용이다. 사이드바  관리자 전용 의 체크를 켜야 나온다.

"로그인했는데 대기 화면만 나와요" → 신청하기를 안 눌렀을 수 있다. 로그인만으로는 접속되지 않는다(2026-08-12 변경).

"승인했는데 못 들어온대요" → 1차만 눌렀는지 확인한다. 2차까지 끝나야 열린다.

"2시간마다 로그아웃돼요" → 정상이다. `SESSION_MAX_SECONDS = 2시간` (구글 토큰 발급 시각 기준).

"팀을 새로 만들었는데 아무것도 안 바뀌었어요" → 페이지를 하나도 체크하지 않으면 기본 메뉴로 되돌아간다. 하나 이상 체크할 것.

6. 손대면 안 되는 것

- `allowed-users.json` 을 직접 편집하지 말 것. 화면에서 바꾸면 파일 락 + 원자적 저장으로 동시 수정 충돌을 막는데, 직접 고치면 그 보호가 없다. 이 파일은 **git 에 절대 올리지 않는다**(실제 직원 메일과 권한이 들어 있다).
- **소유자 목록**(`OWNER_EMAILS`) 은 코드 상수다. 늘리면 관리 화면이 열리는 사람이 늘어난다 — 신중히.
- **페이지 key** 는 한 번 정하면 바꾸지 않는다(`pages_registry.py` 주석). 바꾸면 팀에 저장된 권한이 그 페이지를 못 찾아 조용히 사라진다.

부록 — 권한 확인 순서

누가 무엇을 볼 수 있는지 코드가 판단하는 순서.

1. 로그인했나 → 아니면 로그인 화면
2. 2시간 지났나 → 지났으면 강제 로그아웃
3. **approved** 에 있나 → 없으면 신청/대기 화면 (**stage1** 만 통과해도 여기)
4. 소유자인가 → 맞으면 모든 페이지 + 관리 화면
5. 팀이 있고 체크된 페이지가 있나 → 그 목록
6. 아니면 → 기본 메뉴(**DEFAULT_PAGES**)
7. 관리 화면 요청인가 → 소유자만 (팀으로는 못 연다)

SEOBUK · 콘텐츠운영팀 · 대시보드 접근 권한 가이드 · 2026-08-12